Informe de Evaluación de Vulnerabilidades

Fecha: 1 de enero de 20XX | Marco metodológico: NIST SP 800-30 Rev. 1

1. Descripción del Sistema

El hardware del servidor consta de un procesador potente y 128 GB de memoria. Se ejecuta en la versión más reciente del sistema operativo Linux y aloja un sistema de gestión de bases de datos MySQL. Está configurado con una conexión de red estable mediante direcciones IPv4 e interactúa con otros servidores de la red. Las medidas de seguridad incluyen conexiones cifradas mediante SSL/TLS.

2. Alcance

El alcance de esta evaluación de vulnerabilidades se relaciona con los controles de acceso actuales del sistema. La evaluación cubrirá un período de tres meses, desde octubre de 2026 hasta diciembre de 2026. Se utiliza NIST SP 800-30 Rev. 1 para guiar el análisis de riesgos del sistema de información.

3. Propósito

El servidor de bases de datos es un sistema informático centralizado que almacena y gestiona grandes volúmenes de datos. El servidor se utiliza para almacenar datos de clientes, campañas y analíticas que posteriormente pueden analizarse para monitorizar el rendimiento y personalizar las iniciativas de marketing. Es fundamental proteger el sistema debido a su uso habitual en las operaciones de marketing.

4. Evaluación de Riesgos

A continuación se presenta la matriz de análisis de riesgos identificados en el sistema conforme a la metodología NIST SP 800-30 Rev. 1 (Nivel de Riesgo = Probabilidad × Severidad):

Fuente de amenaza	Evento de amenaza	Probabilidad	Severidad	Riesgo
Ciberdelincuente (Hacker)	Obtener información confidencial mediante exfiltración	3	3	9
Empleado	Interrumpir operaciones de misión crítica	2	3	6
Cliente	Alterar o eliminar información crítica	1	3	3

5. Enfoque (Metodología)

Los riesgos evaluados tuvieron en cuenta los procedimientos de almacenamiento y gestión de datos de la empresa. Las posibles fuentes y eventos de amenaza se determinaron considerando la probabilidad de un incidente de seguridad dados los permisos de acceso abiertos del sistema de información. La

severidad de los incidentes potenciales se ponderó en relación con el impacto en las necesidades operativas del día a día.

6. Estrategia de Remediación

Implementación de mecanismos de autenticación, autorización y auditoría para garantizar que únicamente los usuarios autorizados accedan al servidor de bases de datos. Esto incluye el uso de contraseñas robustas, controles de acceso basados en roles (RBAC) y autenticación multifactor (MFA) para limitar los privilegios de los usuarios. Cifrado de datos en tránsito utilizando TLS en lugar de SSL. Lista de direcciones IP permitidas (IP allowlisting) para las oficinas corporativas con el fin de evitar que usuarios aleatorios desde Internet se conecten a la base de datos.